APPLICATION SECURITY REVIEW

Intake Questionnaire

Acme Payments Portal

Submitted Ticket ASR-2026-041, received 2026-09-08

Complete this form to request an application security review. The AppSec team uses it to set the review depth and to schedule testing. Answers below were completed by the requester (shown in blue italics).

A. Request details

A1 Application name and version	*Acme Payments Portal, 2.7.0 release candidate*
A2 Business owner / product owner	*Dana Whitfield, Head of Merchant Services*
A3 Technical lead	*Ravi Menon*
A4 Business unit and cost centre	*Payments, cost centre 4410*
A5 Reason for review (new release, major change, annual, audit)	*New major release adding settlement exports and diagnostics*
A6 Target go-live date	*2026-10-15*

B. Application overview

B1 What does the application do, and who uses it?	*Back office for merchant-services staff: search transactions, download settlement exports, run network diagnostics. About 60 internal users.*
B2 Internet-facing, internal only, or partner access?	*Internet-facing (staff work remotely; no VPN today)*
B3 Application tier (business criticality)	*Tier 1 (critical)*
B4 Languages, frameworks and runtime	*Python 3.12 standard-library HTTP server, SQLite locally and PostgreSQL in production, Docker on ECS*

C. Data

C1 Most sensitive data processed or stored	*Merchant names, transaction amounts, last four digits of card numbers, staff password hashes*
C2 Data classification	*Restricted*
C3 Regulatory scope (PCI DSS, GDPR, SOX, HIPAA, none)	*PCI DSS (truncated PAN only), GDPR (staff data)*
C4 Data retention and deletion approach	*Ledger kept 7 years; exports deleted after 30 days (manual)*

D. Architecture and hosting

D1 Hosting platform and regions	*AWS eu-west-1: ECS Fargate, RDS PostgreSQL, S3 exports bucket*
D2 Datastores and encryption at rest	*RDS storage encryption: believed on. S3 default encryption: yes.*
D3 Inbound and outbound integrations	*Outbound: acquirer settlement API (nightly). Inbound: staff browsers only.*
D4 Secrets management	*Environment variables and constants in code*

E. Identity and access

E1 How are users authenticated?	*Local username and password stored in the application database*
E2 How is authorisation enforced (roles, ownership checks)?	*Roles planned for next sprint; today all users see everything*
E3 Privileged / admin functions	*/admin user list and /diag network diagnostics*

F. Delivery pipeline

F1 Source control and branch protection	*GitHub; main branch protected, one reviewer*
F2 Automated security checks in CI	*Demo pipeline: secrets, SAST, SCA, IaC, container, DAST*
F3 Open-source dependency management	*Manual updates when someone remembers*
F4 Previous penetration tests or reviews	*None*

G. Declaration

G1 Requester	*Ravi Menon, Technical Lead*
G2 Date submitted	*2026-09-08*

AppSec triage (completed by reviewer)

Assigned tier	Tier 1 (critical)
Review depth	Full review: threat model, manual code review, authenticated testing
Triaged by	AppSec Review Team (demo)
Report ticket	ASR-2026-041